Kerbo-S Requirements Document, Version 2.0 (Sprint 1 Revision)

AI-Assisted Kerberos Security Auditor | CSCE 4907 Senior Capstone

GitHub URL: https://github.com/chancellorr/Cybersecurity-Capstone.git

Team: Chance Edwards, Ben Grider, David Pantoja, Jessica Yescas | Revision date: October 29, 2026 |

Supersedes: Requirements Document v1.0 (approved proposal)

1. Purpose and Revision Summary

This document replaces the v1.0 proposal as the controlling requirements baseline for Kerbo-S. It corrects inconsistencies found in v1.0, closes gaps that would have blocked implementation, and adds requirements discovered while planning the build. Every requirement carries a change tag: **New** (added in v2.0), **Changed** (present in v1.0 but revised), or **Retained** (unchanged). Priority uses MoSCoW (Must, Should, Could). Release R1 is the MVP; R2 is optional if time permits.

1.1 Summary of Significant Changes

#	Change	Reason
C-01	Severity is now computed from the weighted risk score; the per-rule fixed severities in v1.0 are replaced by baseline factor values (Section 6.2).	v1.0 contradicted itself: KC-02 was High in the rule but Critical (76) in Table 7.
C-02	Policy data now maps to KC-03, KC-08, KC-09 (v1.0 Table 9 listed the principal rules KC-01/02/04/05/06 by mistake).	Copy error; the wrong mapping would have sent the collector to the wrong data.
C-03	KC-06 now has a defined data source: `kadm5.acl` plus an admin-justification file.	v1.0 required a documented justification but never said where it lives.
C-04	KC-05, KC-10 and KC-11 read the KDC log (`krb5kdc.log`) and `journalctl`; `/var/log/auth.log` is no longer a primary source.	KDC ticket events are written by the KDC, not by the system auth log. Final paths to be verified in the lab.
C-05	KC-04/KC-05 inactivity logic defined for never-used accounts and for the fact that last-authentication data only updates on initial (AS) requests.	v1.0 logic would produce false positives and could not measure service-principal use.
C-06	Platform narrowed to Linux (Ubuntu). Kerbo-S runs on the KDC host or on an imported snapshot. Windows support removed.	`kadmin.local` only runs on the KDC host; Windows was untestable in the lab.
C-07	KC-11 baseline defined as a configurable fixed threshold (MVP); learned baselines moved to R2.	v1.0 referenced a baseline that was never defined.

#	Change	Reason
C-08	KC-07 expanded to cover 3DES and per-principal key types, not only RC4/DES.	The weak-crypto surface includes principal keys and `allow_weak_crypto`.
C-09	New requirements: snapshot import, evidence hashing, configurable thresholds, headless CLI, LLM provider abstraction with mock mode, AI input sanitization.	Needed to develop without the VM, support the threat model, and make testing repeatable.
C-10	Validation scenarios expanded from 8 to 15 so that all 11 rules, a clean baseline, and AI safety are tested.	v1.0 had no test for KC-06, KC-09, or KC-11.
C-11	Terminology unified: the second actor is the Security Auditor (the v1.0 diagram said Security Analyst). Multi-KDC and Local LLM are R2 only (v1.0 listed Multi-KDC as both a stretch goal and a future enhancement).	Consistency and scope control.
C-12	The AI engine no longer ranks findings independently; displayed priority is always the engine's risk score. AI may only suggest a remediation order, shown separately as advisory.	v1.0 listed AI Finding Prioritization, which conflicted with the rule that AI does not assign risk.
C-13	AI contribution defined: correlation of related findings, advisory remediation order, environment-specific remediation, audience translation (FR-AI-08).	Instructor feedback 3: show what the AI adds that rules alone cannot.
C-14	AI implementation made specific: configurable model, low temperature, schema-validated output, versioned prompts and stored provenance (FR-AI-09); measurable AI evaluation method (Section 7.2).	Feedback 5 and 9: subjective criteria and an undecided AI approach.
C-15	Data collection specified per source with commands, files, privileges, failure behavior and Linux/Windows handling (Section 5.8).	Feedback 6.
C-16	Ground-truth manifests and formal TP/FP/FN/TN definitions added (Section 8.1); completion measures removed from success criteria; compound scenario TV-15 added.	Feedback 4 and 10.
C-17	Threat-to-requirement traceability with residual risk (Section 7.1); report integrity digest and verify function (FR-RPT-05).	Feedback 7.

#	Change	Reason
C-18	MVP defined as all Must/R1 requirements, with an explicit cut order for Should items (Section 5.9).	Feedback 8.

1.2 Instructor Feedback Addressed

All ten items of the previous sprint's feedback are addressed in v2.0; the table maps each item to its resolution.

#	Instructor feedback (summary)	How v2.0 addresses it	Where
1	Define concrete security checks	11 rules with exact logic, default thresholds, data sources and validation scenarios	Section 6.1, FR-AUD-01 to 07
2	Define the risk-classification methodology	Weighted four-factor formula, fixed score bands, baseline factor values per rule; severity comes only from the score, never from AI	Section 6.2, FR-RSK-01 to 04
3	Separate the audit engine from the AI; state what AI adds	Engine runs with no AI configured; AI value defined as correlation, advisory remediation order, environment-specific remediation and audience translation	Section 5.4, FR-AUD-07, FR-AI-08
4	Controlled test environment with ground truth; measure accuracy, FP, FN	15 scenarios with ground-truth manifests and formal TP/FP/FN/TN definitions	Sections 8 and 8.1
5	Measurable AI evaluation criteria	Reference checklists, two-reviewer scoring, re-audit check of recommendations, repeated-run consistency test, usefulness rating	Section 7.2
6	Clarify data collection per source, privileges, Linux and Windows	Per-source commands, files, privileges and failure behavior; Windows handling stated explicitly	Sections 5.1 and 5.8
7	Threat-model Kerbo-S itself	Each threat traced to requirements with residual risk; report integrity digest and verify function	Section 7.1, FR-RPT-05, FR-COL-09
8	Establish an MVP and stretch goals	MVP = all Must/R1 requirements, with an explicit cut order for Should items; R2 list unchanged in spirit	Sections 5.7 and 5.9
9	Narrow the AI	OpenAI API primary with a provider interface; configurable model, low temperature, schema-	FR-AI-02 to

#	Instructor feedback (summary)	How v2.0 addresses it	Where
	implementation	validated output, sanitized structured input, fallback behavior	05, FR-AI-09
10	Better success metrics	Completion measures removed as success criteria; detection rate, FP rate, FN rate, classification accuracy and AI accuracy defined as formulas	NFR-QUA-01, Section 8.1

2. Product Overview and Scope

Kerbo-S is a desktop auditing and decision-support application for an MIT Kerberos realm. It collects principals, policies, configuration files and authentication logs in a read-only fashion, evaluates them with a deterministic rule engine (KC-01 through KC-11), scores each finding with a deterministic risk model, and then uses an AI service only to explain findings, suggest remediation and draft report text.

In scope: read-only collection, 11 audit rules, risk scoring, AI explanations and recommendations, technical and executive reports, PDF export, local SQLite storage, a PyQt6 desktop interface.

Out of scope: automated remediation or enforcement, Active Directory, real-time monitoring, web or cloud deployment, interactive AI chat, Windows hosts, production Kerberos environments.

3. Users and Roles

Role	Needs	Change
Kerberos Administrator	Run audits, review findings and recommendations, generate reports. Needs shell access to the KDC host or a snapshot.	Retained
Security Auditor	Review findings, risk scores and AI explanations; assess compliance; export reports. Read-only use of results.	Changed (renamed from Security Analyst in the diagram)

Both roles use the same application; access control relies on OS file permissions and the KDC administrative access of the user running it (see NFR-SEC-02).

4. Assumptions, Dependencies and Constraints

- **A-01** The lab runs MIT Kerberos on Ubuntu Server LTS in VirtualBox with a KDC, a client and an administrative workstation. (Retained)
- **A-02** Kerbo-S runs on the KDC host with permission to execute `kadmin.local`, or on a workstation using a snapshot exported from the KDC. (New)
- **A-03** KDC logging is enabled to a file or the journal so authentication events exist to analyze. (New)

- **A-04** An external AI provider (OpenAI API) is the primary target; a local model remains an R2 option. (Retained)
- **A-05** Python 3.x, PyQt6 and SQLite are the implementation stack; Git/GitHub is used for version control. (Retained)
- **Constraints:** completion within the Capstone sequence, minimal budget, four team members, desktop application only. (Retained)

5. Functional Requirements

5.1 Data Collection

ID	Requirement	Pri	Rel	Tag	Traces to
FR-COL-01	The system shall enumerate principals with `kadmin.local listprincs` and retrieve each with `getprinc`, capturing name, last password change, last successful authentication, key encryption types, maximum ticket life, attributes and assigned policy.	Must	R1	Retained	UC-02, KC-01/02/04/05/06/07
FR-COL-02	The system shall enumerate policies with `getpols` and retrieve each with `getpol`, capturing minimum length, maximum and minimum life, history and failure-count settings.	Must	R1	Changed	UC-03, KC-03
FR-COL-03	The system shall read `/etc/krb5.conf` and `/etc/krb5kdc/kdc.conf` and extract realm, enctype and lifetime settings (`supported_enctypes`, `permitted_enctypes`, `allow_weak_crypto`, `max_life`, `max_renewable_life`, `ticket_lifetime`, `renew_lifetime`).	Must	R1	Changed	UC-04, KC-07/08/09
FR-COL-04	The system shall read `/etc/krb5kdc/kadm5.acl` and an administrator-supplied justification file listing approved administrative principals.	Must	R1	New	UC-02, KC-06
FR-COL-05	The system shall read KDC authentication events from the KDC	Must	R1	Changed	UC-05, KC-

ID	Requirement	Pri	Rel	Tag	Traces to
	log file and `journalctl`, extracting timestamp, principal, client address, request type and result.				05/10/11
FR-COL-06	Collection shall be read-only; the system shall never execute `kadmin` commands that add, modify, delete or change keys.	Must	R1	Retained	NFR-SEC-01
FR-COL-07	If a source is unreachable, unreadable or malformed, the system shall record a collection error with timestamp and continue with remaining sources.	Must	R1	Retained	UC-01 to UC-05
FR-COL-08	The system shall export collected data as a timestamped snapshot (JSON plus raw artifacts) and shall import a snapshot to run an audit without access to the KDC.	Should	R1	New	TM-01, development workflow
FR-COL-09	The system shall compute and store a SHA-256 hash of every raw artifact at collection time.	Should	R1	New	TM-01, TM-05

5.2 Audit Engine

ID	Requirement	Pri	Rel	Tag	Traces to
FR-AUD-01	The engine shall evaluate rules KC-01 through KC-11 as defined in Section 6.1 and produce one finding per violating object (principal, policy, setting or time window).	Must	R1	Changed	UC-01 to UC-05
FR-AUD-02	Rules shall be deterministic: identical input data and thresholds shall always yield identical findings.	Must	R1	Retained	Success criteria
FR-AUD-03	Rule thresholds (for example 90 days, 180 days, 12 characters, 24 hours, 7 days, 10 failures in 15 minutes) shall be read from a configuration file with the v1.0 values as defaults.	Should	R1	New	KC-01 to KC-11
FR-AUD-04	Each finding shall record rule ID, affected	Must	R1	Changed	NFR-

ID	Requirement	Pri	Rel	Tag	Traces to
	object, observed value, threshold, collection timestamp and a reference to the source artifact and its hash.				AUD-01
FR-AUD-05	The engine shall classify principals as service principals when the name contains an instance component (for example `host/server.example.com`) and is not an administrative or internal principal (`krbtgt/*`, `K/M`, `kadmin/*`).	Must	R1	New	KC-02, KC-05
FR-AUD-06	Principals with no policy assigned shall be reported under KC-03 (extended).	Should	R1	New	KC-03
FR-AUD-07	The engine shall run with no AI service configured and shall never call the AI service to decide whether a finding exists.	Must	R1	Retained	UC-06

5.3 Risk Scoring

ID	Requirement	Pri	Rel	Tag	Traces to
FR-RSK-01	The system shall compute Risk Score = Impact x 0.40 + Exploitability x 0.30 + Exposure x 0.20 + Compliance Impact x 0.10, each factor 0 to 100.	Must	R1	Retained	Section 6.2
FR-RSK-02	Severity shall be derived only from the score: 0-24 Low, 25-49 Medium, 50-74 High, 75-100 Critical.	Must	R1	Changed	C-01
FR-RSK-03	Baseline factor values per rule shall be stored in a configuration file and recorded with each finding so scores can be reproduced and audited.	Must	R1	New	NFR-AUD-01
FR-RSK-04	The system shall display findings sorted by score and shall not allow the AI component to alter a score or severity.	Must	R1	Changed	C-12

5.4 AI Analysis

The AI component adds four things a rule engine cannot, and it never decides whether a finding exists. First, correlation: rules report one object at a time, while the AI can connect them. For example, one service principal with an RC4 key (KC-07), a password older than 180 days (KC-02) and an unjustified

admin entry (KC-06) is a single Kerberoasting-style exposure, not three unrelated items. Second, environment-specific remediation: the observed values become concrete steps, such as the exact `kadmin` policy change or `kdc.conf` line to apply. Third, audience translation: the same findings become a technical report or an executive summary. Fourth, advisory sequencing: a suggested remediation order shown beside the score-sorted list. The specific model is chosen and recorded in the Design Document.

ID	Requirement	Pri	Rel	Tag	Traces to
FR-AI-01	For each validated finding, the AI component shall return a plain-language explanation, risk context and remediation recommendation.	Must	R1	Retained	UC-06
FR-AI-02	The AI component shall receive only structured finding fields built from a fixed prompt template. Raw logs, configuration files, credentials and Kerberos keys shall never be sent.	Must	R1	Retained	TM-02, TM-03
FR-AI-03	Before submission, free-text fields (principal descriptions, log messages) shall be removed or sanitized, and principal and host identifiers shall be pseudonymized when the provider is external.	Must	R1	New	TM-02, TM-03
FR-AI-04	AI access shall go through a provider interface with at least an OpenAI implementation and a mock implementation that returns fixed text for tests and offline development.	Should	R1	New	A-04
FR-AI-05	If the AI service is unavailable, the system shall notify the user and continue all non-AI functions, including report generation without AI sections.	Must	R1	Retained	UC-06
FR-AI-06	AI output shall be labelled as AI-generated and advisory, stored with the finding, and shall require administrator review before inclusion as approved remediation.	Must	R1	Changed	AI limitations
FR-AI-07	The AI component shall generate compliance summary text and technical and executive report narrative from the	Must	R1	Retained	UC-08

ID	Requirement	Pri	Rel	Tag	Traces to
	finding set.				
FR-AI-08	For each audit, the AI component shall receive the findings grouped by affected principal or service and return (a) related-finding groups with a one-sentence rationale each and (b) an advisory remediation order. Both are shown beside, never instead of, the score-sorted list.	Should	R1	New	UC-06, TV-15
FR-AI-09	AI calls shall use a configurable model name, a temperature of 0.2 or lower and a JSON response schema. A response that fails schema validation shall be retried once, then marked unavailable. The model name, prompt-template version and timestamp shall be stored with every AI output.	Must	R1	New	TM-02, Section 7.2

5.5 Reporting and Export

ID	Requirement	Pri	Rel	Tag	Traces to
FR-RPT-01	The system shall generate a technical report: findings, scores, affected objects, evidence references, AI explanations and recommendations.	Must	R1	Retained	UC-08
FR-RPT-02	The system shall generate an executive report: posture summary, counts by severity, top risks and recommended priorities.	Should	R1	Retained	UC-08
FR-RPT-03	The system shall export any report to PDF to a user-selected location and confirm success or report failure.	Must	R1	Retained	UC-09
FR-RPT-04	Each report shall include audit ID, generation timestamp, collection timestamp, tool version and the rule set version.	Should	R1	New	NFR-AUD-01
FR-RPT-05	Each report shall embed a SHA-256 digest of the finding set it was generated from and	Should	R1	New	TM-05

ID	Requirement	Pri	Rel	Tag	Traces to
	store the digest in the database. A verify function shall recompute the digest and report any mismatch.				

5.6 Storage, Interface and Operation

ID	Requirement	Pri	Rel	Tag	Traces to
FR-UI-01	The PyQt6 interface shall let the user start an audit, choose live collection or snapshot import, and view progress and errors.	Must	R1	Changed	UC-01
FR-UI-02	A findings dashboard shall list findings with severity, score, rule, object and status, with filtering by severity and category.	Must	R1	Retained	UC-07
FR-UI-03	A finding detail view shall show observed value, threshold, evidence reference, score factors and AI analysis.	Must	R1	Changed	UC-07
FR-UI-04	The user shall be able to mark a finding as reviewed or validated and add a note.	Should	R1	Retained	UC-07
FR-UI-05	The application shall provide a headless command-line mode that runs collection, audit and scoring and writes JSON results, for automated tests.	Should	R1	New	Testing
FR-DB-01	Audits, findings, scores, collection errors, artifact hashes and reports shall be persisted in a local SQLite database.	Must	R1	Changed	UC-01
FR-DB-02	Stored findings shall be immutable after generation except for review status and notes.	Must	R1	Retained	TM-05

5.7 Release 2 (Optional)

ID	Requirement	Pri	Rel	Tag
FR-R2-01	Historical audit search with filters by date, rule and severity (UC-10).	Could	R2	Retained

ID	Requirement	Pri	Rel	Tag
FR-R2-02	Audit logging of user actions.	Could	R2	Retained
FR-R2-03	Dashboard analytics and trends across audits.	Could	R2	Retained
FR-R2-04	Local LLM provider (for example Llama) behind the provider interface.	Could	R2	Retained
FR-R2-05	Learned per-principal ticket-request baselines for KC-11.	Could	R2	New
FR-R2-06	Advanced compliance reporting.	Could	R2	Retained

Multi-KDC support is moved out of the stretch list to Future Enhancements to remove the v1.0 duplication.

5.8 Data-Collection Implementation (New)

Collection runs as a local Python module that executes fixed, allow-listed commands (argument lists, no shell, names validated against the principal-name pattern) or reads files, then stores the raw output and its SHA-256 hash before any parsing.

Source	How obtained	Commands / files	Privilege required	Rules	On failure
Principals	Subprocess on the KDC host	`kadmin.local -q listprincs`; `kadmin.local -q 'getprinc NAME'`	Root or sudo right to run `kadmin.local` (reads the KDC database)	KC-01, 02, 04, 06, 07	Record error, skip dependent rules
Policies	Subprocess on the KDC host	`kadmin.local -q getpols`; `kadmin.local -q 'getpol NAME'`	Same as principals	KC-03, 08	Record error, skip dependent rules
Configuration	File read	`/etc/krb5.conf`, `/etc/krb5kdc/kdc.conf`, `/etc/krb5kdc/kadm5.acl`	Read permission on those files (normally root)	KC-06, 07, 08, 09	Record error, continue
Admin justification	File read	`admin_justifications` file in the application config folder	Owner-only read	KC-06	KC-06 reports every admin as unjustified and flags the missing file

Source	How obtained	Commands / files	Privilege required	Rules	On failure
Authentication logs	File read, or `journalctl -u krb5-kdc --since`	KDC log path from the `[logging]` section of `kdc.conf`; journal as fallback	Root, or membership in a log-reading group such as `adm`	KC-05, 10, 11	Record error, continue
Snapshot import	File read of a prior export	Snapshot folder created by FR-COL-08	File read only; hashes verified on load	All	Reject on hash mismatch

Final log paths, journal unit name and message formats are verified in the lab (Open Decision 3).

Platform handling. Linux (Ubuntu Server LTS) is the supported platform for Kerbo-S and for the KDC. Windows is not supported as a host in v2.0: `kadmin.local` exists only where the MIT KDC runs, and the lab has no Windows KDC. A Windows workstation can still be a Kerberos client of the lab KDC, and its activity is audited through KDC logs. Windows-hosted KDCs and Active Directory use different tools and logs and remain under Future Enhancements. v1.0 Table 1 listed Linux and Windows, so this reduction needs instructor confirmation (Open Decision 5).

5.9 MVP Definition and Cut Order (New)

The MVP is every requirement tagged Must and R1. A successful final system therefore collects all four sources (live or from a snapshot), runs KC-01 through KC-11, scores and stores the findings, shows them in the dashboard, produces AI explanations with a working fallback, exports a technical PDF report, and meets the Section 8.1 metrics. If the schedule slips, R1 Should items are cut in this order: FR-UI-05 (command-line mode), FR-RPT-02 (executive report), FR-AI-08 (correlation), FR-UI-04 (review notes), FR-AUD-06 (principals without a policy), FR-AI-04 (provider interface beyond OpenAI). FR-COL-08, FR-COL-09 and FR-RPT-05 are not cut because they support the threat model. R2 items start only after the MVP passes validation.

6. Audit Rule Specification

6.1 Rules (all Retained unless noted)

Rule	Logic (defaults)	Data source	Tag
KC-01	User principal password age > 90 days	`getprinc` last password change	Retained
KC-02	Service principal password age > 180 days	`getprinc` last password change, FR-AUD-05	Changed
KC-03	Policy minimum password length < 12; also principals with no policy	`getpol`, `getprinc` policy	Changed

Rule	Logic (defaults)	Data source	Tag
KC-04	User principal with no successful authentication in > 180 days; never-authenticated accounts measured from creation date	`getprinc` last successful authentication	Changed
KC-05	Service principal with no ticket request in > 180 days	KDC log TGS requests (the `getprinc` field is not updated by service-ticket use)	Changed
KC-06	Administrative principal (admin instance or privileged ACL entry) not in the justification file	`kadm5.acl`, justification file	Changed
KC-07	RC4, DES, 3DES or `allow_weak_crypto = true` configured, or a principal holding such keys	`kdc.conf`, `krb5.conf`, `getprinc` key list	Changed
KC-08	Configured ticket lifetime > 24 hours	`kdc.conf`, `krb5.conf`, policy/principal max life	Retained
KC-09	Configured renewable lifetime > 7 days	`kdc.conf`, `krb5.conf`	Retained
KC-10	At least 10 failed authentications for one principal or source within 15 minutes	KDC log pre-authentication failures	Changed
KC-11	Ticket requests per principal in a 15-minute window exceed a configurable threshold (default to be set after lab calibration)	KDC log request counts	Changed

6.2 Baseline Risk Factors and Resulting Severity (Changed)

Scores are computed with the FR-RSK-01 formula and replace Table 7 of v1.0. KC-02 resolves to High and KC-07 to 88.5 (the v1.0 worked example) to remove the earlier contradictions. The team may tune baselines, but any change must be recorded in the Change Document.

Rule	Impact	Exploitability	Exposure	Compliance	Score	Severity
KC-01	40	35	30	60	38.5	Medium
KC-02	80	60	60	80	70.0	High
KC-03	70	50	70	80	65.0	High
KC-04	35	30	35	50	35.0	Medium
KC-05	35	30	35	50	35.0	Medium
KC-06	80	55	60	75	68.0	High
KC-07	95	85	80	90	88.5	Critical

Rule	Impact	Exploitability	Exposure	Compliance	Score	Severity
KC-08	45	35	45	45	42.0	Medium
KC-09	40	35	45	45	40.0	Medium
KC-10	70	75	75	55	71.0	High
KC-11	65	60	65	40	61.0	High

7. Non-Functional Requirements

ID	Category	Requirement	Pri	Tag
NFR-SEC-01	Security	Kerbo-S shall operate read-only with respect to the Kerberos environment and shall request least-privilege access.	Must	Retained
NFR-SEC-02	Security	The database, snapshots and reports shall be created with owner-only file permissions (for example 600/700).	Must	New
NFR-SEC-03	Security	API keys shall be supplied through environment variables or encrypted configuration, never stored in source code or the repository.	Must	Retained
NFR-SEC-04	Security	Input from logs and configuration shall be validated for format and length before parsing; parsing failures shall not crash the audit.	Must	Changed
NFR-SEC-05	Security	The system shall document exactly which fields are sent to an external AI service.	Should	Retained
NFR-AUD-01	Auditability	Every finding shall be reproducible from stored source artifacts, thresholds, rule version and factor values.	Must	New
NFR-REL-01	Reliability	A failure in one collector, rule or the AI service shall not stop other audit stages; failures shall be logged.	Must	Retained
NFR-PERF-01	Performance	An audit of the lab realm (up to 500 principals and 100,000 log lines) shall complete in under 5 minutes excluding	Should	New

ID	Category	Requirement	Pri	Tag
		AI calls.		
NFR-PERF-02	Performance	The interface shall stay responsive during an audit by running collection and analysis off the UI thread.	Should	New
NFR-USE-01	Usability	A trained administrator shall be able to run an audit and export a PDF in no more than 5 user actions.	Should	New
NFR-PORT-01	Portability	Supported platform is Ubuntu Linux with Python 3.x; installation shall use a pinned `requirements.txt`.	Must	Changed
NFR-MNT-01	Maintainability	Rules shall be independent, individually unit-tested modules; each rule shall have at least one passing and one failing test.	Must	New
NFR-QUA-01	Quality	Targets: detection rate at least 95%, false positives under 10%, risk-classification accuracy at least 95%, AI explanation and recommendation accuracy at least 90%, AI response consistency at least 95%, usefulness at least 4.0/5, 100% report and PDF success.	Must	Retained

Note: the v1.0 false-negative target (under 5%) is the complement of the 95% detection rate, so it is reported together with it and not treated as a separate metric.

7.1 Threat-Model Traceability (New)

Every threat from v1.0 now maps to requirements and a stated residual risk.

Threat	Mitigating requirements	Residual risk
TM-01 Manipulated input	FR-COL-07, 08, 09; NFR-SEC-04; TV-14	An attacker with root on the KDC can alter data before collection; hashing detects only later changes
TM-02 Prompt injection	FR-AI-02, 03, 09; TV-13	Legitimate fields can still yield weak text; output is labelled advisory and reviewed
TM-03 AI service data exposure	FR-AI-02, 03; NFR-SEC-05; R2 local provider (FR-R2-04)	The external provider still sees pseudonymized finding data

Threat	Mitigating requirements	Residual risk
TM-04 API credential theft	NFR-SEC-02, 03	A key in an environment variable is readable by same-user processes; rotate regularly
TM-05 Audit result manipulation	FR-DB-02, FR-COL-09, FR-RPT-05, NFR-AUD-01	A local administrator can edit the database; the verify function detects it only when run
TM-06 Unauthorized report access	NFR-SEC-02	Exported PDFs leave the control of the application
TM-07 Malicious local user	NFR-SEC-01, 02; FR-COL-09; FR-R2-02	No per-user login in the MVP; relies on OS accounts until action logging (R2)

7.2 AI Evaluation Method (New)

Before any AI output is scored, the team writes a reference checklist per rule: three to five required facts covering what the finding means, why it matters and the correct remediation, taken from MIT Kerberos documentation. The minimum sample is 11 rules x 5 runs = 55 outputs, plus TV-15.

Metric	Definition and procedure	Target
Explanation accuracy	Share of explanations containing every required fact and no incorrect technical statement, judged independently by two reviewers; disagreements settled by discussion	90% or higher
Recommendation accuracy	Share of recommendations whose steps are valid for MIT Kerberos and, applied on a disposable lab clone, make the finding disappear on re-audit	90% or higher
Response consistency	Each finding is submitted 5 times; it is consistent when all 5 outputs contain the same required facts and the same recommended actions; reported as the share of consistent findings	95% or higher
Usefulness	5-point rating (clarity, actionability, correctness) by at least 4 reviewers; mean score	4.0 or higher
Correlation quality	Recall of the planted related-finding group in TV-15, plus the share of groups reviewers judge unsupported	Recall 80% or higher; unsupported 10% or lower
Score integrity	AI calls that change a score or severity (blocked by the schema and tested) and TV-13 injection test	0 changes; test passes

8. Validation Scenarios (Changed: 8 to 15)

ID	Configuration	Expected result	Tag
TV-01	User password older than 90 days	KC-01 detected	Retained
TV-02	Service password older than 180 days	KC-02 detected	Retained
TV-03	Minimum password length below 12	KC-03 detected	Retained
TV-04	User inactive more than 180 days	KC-04 detected	Retained
TV-05	Service principal unused more than 180 days	KC-05 detected	Retained
TV-06	RC4 or DES enabled	KC-07 detected	Retained
TV-07	Ticket lifetime above 24 hours	KC-08 detected	Retained
TV-08	10 or more failed logins in 15 minutes	KC-10 detected	Retained
TV-09	Admin principal without a justification entry	KC-06 detected	New
TV-10	Renewable lifetime above 7 days	KC-09 detected	New
TV-11	Burst of ticket requests above threshold	KC-11 detected	New
TV-12	Compliant baseline realm	No findings (false-positive check)	New
TV-13	Log line containing prompt-injection text; AI service disabled	Text is sanitized before submission; audit and report still complete	New
TV-14	Tampered snapshot (hash mismatch)	Mismatch reported; audit flagged	New
TV-15	One service principal with an RC4 key, a password older than 180 days and an unjustified admin ACL entry	KC-02, KC-06 and KC-07 detected; AI groups the three as one related exposure	New

8.1 Ground Truth and Detection Metrics (New)

Each scenario ships with an `expected_findings` manifest listing the (rule, object, severity) triples that must appear and those that must not. Manifests are written and committed before the audit is run. The evaluation unit is one (rule, object) pair, and a script computes the metrics over all scenarios and saves the output in the test report.

Metric	Formula	Target
Detection rate	TP / (TP + FN)	95% or higher
False-negative rate	FN / (TP + FN)	under 5%
False-positive rate	FP / (FP + TN)	under 10%
Risk-classification accuracy	Findings with the expected severity / TP	95% or higher

TP is expected and reported; FN is expected but missed; FP is reported but not expected; TN is evaluated, not expected and not reported. Completion measures such as the share of requirements implemented or the number of open defects are tracked on Trello and are not success criteria.

9. Traceability Overview

Use case	Functional requirements	Rules	Tests
UC-01 Run Security Audit	FR-COL-06/07/08, FR-AUD-01, FR-UI-01, FR-DB-01	All	TV-12, TV-14
UC-02 Analyze Principals	FR-COL-01/04, FR-AUD-05	KC-01, 02, 04, 05, 06	TV-01, 02, 04, 05, 09
UC-03 Review Credential Policies	FR-COL-02, FR-AUD-06	KC-03	TV-03
UC-04 Analyze Configuration	FR-COL-03	KC-07, 08, 09	TV-06, 07, 10
UC-05 Analyze Authentication Logs	FR-COL-05	KC-05, 10, 11	TV-05, 08, 11
UC-06 Generate AI Analysis	FR-AI-01 to 09	n/a	TV-13
UC-07 Review Findings	FR-UI-02/03/04, FR-RSK-02/04	All	UI tests
UC-08 Generate Audit Report	FR-RPT-01/02/04/05, FR-AI-07	n/a	Report validation
UC-09 Export PDF Report	FR-RPT-03	n/a	PDF export test
UC-10 Search Historical Audits	FR-R2-01	n/a	R2

10. Sprint 1 Status and Sprint 2 Scope

Item	Status (confirm with team)
Kerberos lab VM (MIT Kerberos)	Complete per Sprint 1 reflection
Requirements document v2.0	This document

Item	Status (confirm with team)
Design document	Completed
Change document and draft test plan	Completed
GitHub repository and Trello board	Repository created; Trello updated
Prototype	Not started

Sprint 2 scope: lab fixtures for TV-01 to TV-12, collectors (FR-COL-01 to 05, 08, 09), audit engine with KC-01 to KC-11 and unit tests, risk scoring, SQLite schema, and a first PyQt6 window with a findings table. AI integration and PDF reporting follow after the engine passes its tests.

11. Open Decisions

1. Confirm the written feedback from the previous sprint (Section 1.2).
2. Confirm the KC-02 decision (High at 70.0) versus Critical.
3. Confirm the final KDC log path and message formats in the lab (KC-05, KC-10, KC-11).
4. Choose the KC-11 default threshold after observing normal lab traffic.
5. Confirm Ubuntu-only support with the instructor.